

NorthBridge Technology Solutions Inc.
Information Security Management System

Vendor Management Policy
POL-005

DOCUMENT CONTROL	
Policy Title	Vendor Management Policy
Policy ID	POL-005
Version	1.0
Date	05/17/2026
Author	Ashkon Irani
Reviewed By	IT Director
Approved By	Chief Executive Officer
Classification	Confidential
Applies To	All NorthBridge staff involved in procuring, managing, or offboarding third-party vendors
Review Frequency	Annual, or following a significant vendor security incident or change to the vendor landscape
Related Documents	POL-001, POL-004, NB-ISMS-002, NB-ISMS-004 (RSK-007, RSK-015, RSK-019)
ISO 27001 Controls	5.19, 5.20, 5.21, 5.22, 5.23

1. Purpose

This Vendor Management Policy defines how NorthBridge Technology Solutions Inc. identifies, assesses, onboards, monitors, and offboards third-party vendors who process, store, transmit, or have access to NorthBridge information assets or Government of Canada client data. Third-party vendor relationships represent one of the most significant and frequently underestimated sources of information security risk in any organization.

The consequences of a vendor's security failure can be as severe as a direct attack on NorthBridge itself. When a vendor that processes NorthBridge employee data is breached, NorthBridge bears

responsibility to affected individuals under PIPEDA. When a vendor that supports GoC client environments fails, NorthBridge may be in breach of its client contracts. When a software vendor introduces a vulnerability into code that NorthBridge deploys to government systems, NorthBridge becomes a link in a supply chain attack. This policy ensures that vendor risk is treated with the same rigour as internal risk.

This policy directly addresses risks of RSK-007 (third-party vendor breach affecting NorthBridge data), RSK-015 (employee data breach via HR system), and RSK-021 (inadequate supply chain security) as documented in the NorthBridge Risk Register (NB-ISMS-004).

2. Scope

This policy applies to all third-party vendors, suppliers, contractors, and service providers who:

- Process, store, transmit, or have access to NorthBridge Confidential or Restricted information assets
- Provide software, hardware, or services that are integrated into NorthBridge's production or client-facing environments
- Have network connectivity to NorthBridge internal systems or Government of Canada client environments
- Provide outsourced development, managed services, or professional services that involve access to NorthBridge systems

This policy applies to all NorthBridge employees and departments involved in identifying, selecting, contracting, managing, or terminating vendor relationships. Procurement decisions that involve any vendor meeting the above criteria must be reviewed by the IT Director before the contract is signed.

This policy does not apply to vendors whose products or services are used solely for publicly available information and who have no access to NorthBridge systems, networks, or data.

3. Vendor Risk Tiering

Not all vendors present the same level of risk to NorthBridge. A vendor that hosts Protected B government data presents a fundamentally different risk profile from one that supplies office stationery. NorthBridge applies a four-tier vendor risk classification to ensure that assessment effort and contractual requirements are proportionate to the risk each vendor presents.

Tier	Risk Level	Criteria	NorthBridge Examples
1	Critical	Vendors who process, store, or transmit Protected B GoC client data. Vendors with direct network access to client environments. Vendors who provide security controls relied upon NorthBridge's ISMS.	Microsoft Azure, Microsoft 365, Cisco AnyConnect VPN provider, external MSSP, cloud security tooling vendors.
2	High	Vendors who process NorthBridge employee personal information. Vendors with access to Confidential systems or data. Software vendors whose products are deployed in	BambooHR (HR data), 1Password Teams (credential management), ServiceNow, Azure DevOps third-party integrations.

		NorthBridge production environments.	
3	Medium	Vendors with access to Internal NorthBridge information. Software-as-a-service providers used for non-critical business functions. Vendors with physical access to NorthBridge facilities.	Workplace productivity tools, video conferencing platforms, facilities management contractors, office supply vendors with facility access.
4	Low	Vendors with no access to NorthBridge systems or data. Vendors who provide goods or services with no information security implications.	Office equipment suppliers, catering vendors, courier services, publicly available software without NorthBridge integration.

Vendor tier classification is assigned by the IT Director in consultation with the Procurement team at the time of initial vendor identification. Tier classification must be reviewed annually and updated whenever a vendor's scope of service changes in a way that affects their access to NorthBridge information assets.

4. Vendor Lifecycle

Every vendor relationship at NorthBridge follows a structured lifecycle from initial identification through offboarding. Each stage of the lifecycle has defined requirements that must be completed before progressing to the next stage.

4.1 Stage 1 - Vendor Identification and Initial Screening

Before any vendor is engaged for a service falling within the scope of this policy, the requesting department must notify the IT Director and provide the following information:

- The vendor's name, registered business address, and primary business activity
- A description of the service or product being procured
- The category and volume of NorthBridge or client data the vendor will access or process
- Whether the vendor will have network connectivity to NorthBridge or GoC client systems
- The proposed contract value and duration
- Whether the data to be processed will be stored or processed outside Canada

The IT Director assigns a tier classification based on this information and determines the level of assessment required before the vendor can be onboarded. No contract may be signed with a Tier 1 or Tier 2 vendor until a satisfactory security assessment has been completed.

4.2 Stage 2 - Security Assessment

The security assessment process is scaled to the vendor's tier classification. The following requirements apply by tier.

Tier	Assessment Type	Minimum Requirements
------	-----------------	----------------------

Tier 1 -- Critical	Full security assessment	Completion of NorthBridge Vendor Security Questionnaire (VSQ). Review of current SOC 2 Type II or ISO 27001 certificate (must be less than 12 months old). Penetration test results from the past 12 months. Review of incident response and business continuity capabilities. IT Director review and approval. CEO notification for vendors processing GoC client data.
Tier 2 -- High	Standard security assessment	Completion of NorthBridge Vendor Security Questionnaire (VSQ). Evidence of SOC 2 Type II, ISO 27001, or equivalent security certification. Review of data processing and incident notification procedures. IT Director review and approval.
Tier 3 -- Medium	Simplified assessment	Completion of an abbreviated vendor security questionnaire. Review of vendor's published privacy policy and security documentation. IT Manager review and approval.
Tier 4 -- Low	No formal assessment required	Standard procurement process applies. No security assessment required given absence of information security risk. Procurement team records vendor as Tier 4 in the vendor register.

Where a vendor is unable or unwilling to provide the documentation required for their tier assessment, this must be treated as a significant risk indicator. The IT Director must decide whether to proceed with an enhanced assessment, require additional contractual security obligations as a condition of engagement, or decline to engage the vendor.

4.3 Stage 3 - Contractual Security Requirements

All Tier 1, 2, and 3 vendors must agree to contractual security requirements before onboarding. These requirements are in addition to standard commercial contract terms and are not negotiable for vendors in these tiers. The following minimum requirements must be included in all contracts with in-scope vendors.

4.3.1 Requirements for All In-Scope Vendors (Tier 1, 2, and 3)

- The vendor must implement and maintain information security controls proportionate to the classification of NorthBridge data they process
- The vendor must notify NorthBridge in writing within 24 hours of discovering any security incident that affects or may affect NorthBridge data or systems
- The vendor must cooperate fully with any NorthBridge security investigation or audit relating to their services
- The vendor must not subcontract the processing of NorthBridge data to any third party without prior written approval from NorthBridge
- The vendor must securely delete or return all NorthBridge data within 30 days of contract termination
- The vendor must comply with all applicable privacy legislation including PIPEDA for personal information processed on behalf of NorthBridge

4.3.2 Additional Requirements for Tier 1 Vendors (Critical)

- The vendor must maintain an ISO 27001 certification or SOC 2 Type II attestation and provide updated evidence annually

- The vendor must conduct and share results of annual penetration testing of systems used to process NorthBridge or GoC client data
- The vendor must notify NorthBridge within 4 hours of any incident affecting systems that process Protected B GoC client data
- The vendor must agree to NorthBridge's right to conduct or commission an independent security audit of their environment with reasonable notice
- The vendor must confirm that all data processing occurs within Canada unless explicitly approved in writing by NorthBridge and the relevant GoC client
- The vendor must maintain a documented and tested incident response plan and business continuity plan and provide evidence of testing upon request

4.3.3 Data Processing Agreements

All Tier 1 and Tier 2 vendors who process personal information on behalf of NorthBridge must sign a Data Processing Agreement (DPA) that specifies the lawful basis for processing, the categories of personal information processed, the purposes for which it is processed, data subject rights obligations, breach notification procedures, and data deletion requirements. The DPA must comply with PIPEDA and, where applicable, the requirements of Government of Canada privacy directives.

4.4 Stage 4 -- Vendor Onboarding

Upon satisfactory completion of the security assessment and signing of all required contractual documents, the vendor may be formally onboarded. The following onboarding activities must be completed before the vendor is granted access to NorthBridge systems or data.

- The vendor is added to the NorthBridge Vendor Register with their tier classification, assessment date, contract expiry date, and next review date recorded
- System access is provisioned through the standard access management process defined in POL-003. Vendor access is limited to the minimum required for the services being provided
- A named NorthBridge Vendor Owner is assigned for each vendor relationship. The Vendor Owner is the primary point of contact for security matters and is accountable for ongoing monitoring of the vendor relationship
- The Vendor Owner conducts an initial briefing with the vendor's primary security contact to confirm mutual understanding of security requirements, incident notification procedures, and contact details
- All vendor access credentials and certificates are recorded in the NorthBridge Vendor Access Register maintained by the IT Director

4.5 Stage 5 -- Ongoing Monitoring

Onboarding a vendor does not end NorthBridge's security obligations toward that relationship. The threat of landscape changes, vendors change, and the scope of services often expands over time. Ongoing monitoring ensures that vendor risk remains at an acceptable level throughout the relationship.

Tier	Review Frequency	Review Activities	Owner
Tier 1 -- Critical	Annually plus continuous monitoring	Full reassessment using VSQ. Verify current security certification. Review incident history. Review penetration	IT Director

		test results. Confirm data residency compliance.	
Tier 2 -- High	Annually	Standard VSQ reassessment. Verify that security certification remains current. Review any incidents reported during the year. Confirm contract terms remain adequate.	IT Director
Tier 3 -- Medium	Every 2 years	Abbreviated reassessment. Review of any significant changes to vendor service scope or security posture. Confirm the contact details current.	IT Manager
Tier 4 -- Low	No ongoing review required	Reclassify to a higher tier if scope of service changes to include information security implications.	Procurement team

In addition to scheduled reviews, the Vendor Owner must escalate a vendor for an unscheduled security review if any of the following occur:

- The vendor reports a security incident that may affect NorthBridge data
- A security incident at the vendor is reported publicly even if NorthBridge has not been directly notified
- The vendor undergoes a significant corporate change such as acquisition, merger, or change of key security personnel
- The vendor requests a material change to the scope of services that would affect their access to NorthBridge or client data
- NorthBridge identifies anomalous activity associated with the vendor's access credentials or data transfers

4.6 Stage 6 -- Vendor Offboarding

When a vendor relationship ends, whether by contract expiry, termination for cause, or mutual agreement, a formal offboarding process must be completed to ensure that all access is revoked, and all data is returned or destroyed.

The following offboarding activities must be completed within 30 days of contract termination:

#	Action	Detail and Responsibility
1	Revoke all system access	All vendor accounts, credentials, API keys, and certificates are revoked by the IT Manager on or before the contract termination date. Confirmation of revocation is documented in the Vendor Access Register.
2	Recover or delete NorthBridge data	The Vendor Owner confirms with the vendor that all NorthBridge data has been securely deleted or returned. For Tier 1 vendors, written confirmation and a certificate of destruction are required.

3	Return or destroy NorthBridge property	Any NorthBridge-owned hardware, documentation, or credentials held by the vendor are returned or destroyed. Confirmation is documented.
4	Conduct exit security review	The IT Director reviews the vendor relationship for any unresolved security concerns, open incidents, or data handling questions. Findings are documented in the vendor's record.
5	Update Vendor Register	The vendor record is marked as offboarded with the termination date, reason for termination, and offboarding completion confirmation. Records are retained for 7 years.
6	Notify GoC client if applicable	Where the offboarded, vendor had access to GoC client data, the relevant client security contact is notified of the termination and provided with confirmation that all client data has been deleted from vendor systems.

5. Vendor Security Questionnaire

The NorthBridge Vendor Security Questionnaire (VSQ) is the primary tool used to assess a vendor's security posture. It is completed by the vendor and reviewed by the IT Director or IT Manager depending on the vendor's tier. The VSQ covers the following security domains.

Security Domain	Key Areas Assessed
Governance and Policy	Does the vendor have a documented information security policy approved by senior management? Is it reviewed annually? Do they have a named security officer or equivalent role?
Risk Management	Does the vendor conduct formal information security risk assessments? How frequently? Are risk treatment plans maintained and monitored?
Access Control	How does the vendor manage user access to systems that process NorthBridge data? Is MFA enforced? Are privileged access controls in place? How is access reviewed and revoked?
Data Protection and Encryption	How is NorthBridge data encrypted at rest and in transit? Where is data stored geographically? Is data segregated from other client data? What is the data retention and deletion process?
Incident Response	Does the vendor have a documented incident response plan? Have they experienced any security incidents in the past 24 months? What is their process for notifying clients of incidents?
Business Continuity	Does the vendor have a documented and tested business continuity plan? What is their recovery time objective for the services provided to NorthBridge? When was it last tested?
Vulnerability Management	Does the vendor have a formal patch management process? How quickly are critical vulnerabilities remediated? Do they conduct penetration testing? How frequently?
Supply Chain Security	Does the vendor assess the security of their own third-party suppliers? Are subcontractors subject to equivalent security requirements? Has the vendor experienced a supply chain security incident?

Certifications and Compliance	Does the vendor hold ISO 27001 certification, SOC 2 Type II attestation, or equivalent? Is it current? Are they subject to any regulatory requirements relevant to the services they provide to NorthBridge?
Physical Security	What physical security controls protect facilities where NorthBridge data is processed or stored? Is data centre access logged and reviewed?

VSQ responses are scored by the IT Director using the NorthBridge vendor risk scoring rubric. Vendors scoring below the minimum threshold for their tier are not approved for onboarding unless they provide a credible and time-bound remediation plan for identified gaps, which is reviewed and approved by the IT Director before contract execution.

6. Cloud Service Providers

Cloud service providers represent a specific and high-risk category of vendor given the volume and sensitivity of data processed in cloud environments. NorthBridge's primary cloud platform is Microsoft Azure, which hosts GoC Protected B client workloads. The following additional requirements apply to all cloud service providers used by NorthBridge.

- All cloud services used to process NorthBridge or client data must be approved by the IT Director before procurement or use. Unapproved cloud services discovered in use by staff or teams are treated as a shadow IT risk and a policy violation
- Cloud services must store NorthBridge and GoC client data exclusively within Canada unless explicitly approved in writing by the IT Director and, for GoC data, by the relevant government client. Canadian data residency is a contractual obligation under most NorthBridge government contracts
- Cloud providers must hold SOC 2 Type II attestation or ISO 27001 certification covering the services used by NorthBridge. Evidence must be reviewed annually
- The shared responsibility model for each cloud service must be documented, confirming which security controls are the responsibility of the cloud provider and which are the responsibility of NorthBridge. NorthBridge is responsible for all controls in its area of the shared responsibility model regardless of the cloud provider's own security posture
- Cloud Security Posture Management tooling must be used to continuously monitor the configuration of all cloud environments processing NorthBridge or client data for misconfigurations and deviations from the approved security baseline
- Cloud provider outages and security advisories must be monitored by the IT team. Any advisory affecting NorthBridge's use of the service must be assessed and responded to within the timeframe specified in the advisory or within 48 hours if no timeframe is given

7. Software Supply Chain Security

NorthBridge develops and deploys software to Government of Canada client environments. The security of the software supply chain - including all third-party libraries, open-source components, and development tools -- is therefore both a NorthBridge responsibility and a GoC client concern. A vulnerability introduced via a third-party software component can be as damaging as a direct attack.

- All third-party software libraries and open-source components used in NorthBridge software products must be inventoried in a Software Bill of Materials (SBOM) maintained by the Development Lead

- The SBOM must be reviewed for known vulnerabilities using an automated software composition analysis tool integrated into the NorthBridge CI/CD pipeline. Builds containing components with Critical or High severity vulnerabilities must not be deployed to production until the vulnerability is resolved
- The Development Lead must subscribe to security advisories for all significant third-party components used in NorthBridge software. Critical vulnerabilities must be triaged within 24 hours of advisory publication
- Third-party development tools and IDE plugins must be approved by the IT Director before use on systems that access NorthBridge or client code or data
- Any GoC client that requests an SBOM for software deployed to their environment must be provided one within 5 business days of the request

8. Vendor Register

The IT Director maintains a Vendor Register documenting all in-scope vendor relationships. The Vendor Register is a Restricted document stored in the NorthBridge SharePoint environment and is accessible only to the IT Director, IT Manager, and designated Vendor Owners.

The Vendor Register contains the following information for each vendor:

- Vendor name, registered business address, and primary contact details
- Tier classification and classification rationale
- Services provided and data assets accessed
- Contract start and expiry dates
- Date of last security assessment and outcome
- Date of next scheduled review
- Current security certification details and expiry dates
- Named Vendor Owner at NorthBridge
- Incident history relevant to the vendor relationship
- Offboarding completion date if the relationship has ended

The Vendor Register is reviewed in its entirety by the IT Director on a quarterly basis to confirm that all vendor relationships are current, all assessments are within their review window, and no vendor has experienced a security event that requires an unscheduled review.

9. Roles and Responsibilities

Role	Vendor Management Responsibilities
IT Director	Owns this policy and the overall vendor risk management program. Assigns tier classifications. Approves all Tier 1 and Tier 2 vendors. Reviews and approves of VSQ assessments. Maintains the Vendor Register. Escalates vendor security incidents to the CEO and GoC clients as required. Approves all contractual security clauses for Tier 1 vendors.
IT Manager	Conducts Tier 3 vendor assessments. Manages vendor access provisioning and deprovisioning. Maintains the Vendor Access Register. Monitors vendor access activity for anomalies. Coordinates vendor offboarding activities.

Procurement Team	Identifies new vendor requirements and notifies the IT Director before contract negotiations begin. Ensures security requirements are included in all vendor contracts. Maintains a record of all Tier 4 vendors. Does not sign contracts with Tier 1, 2, or 3 vendors without IT Director signing-off on the security assessment.
Vendor Owner	The named NorthBridge employee is responsible for the day-to-day management of a specific vendor relationship. Monitors vendor performance and security posture. Escalates security concerns to the IT Director. Initiates the offboarding process when a vendor relationship ends. Keeps vendor contact details current in the Vendor Register.
Legal Counsel	Reviews and approves Data Processing Agreements and security addenda for Tier 1 and Tier 2 vendor contracts. Advises on PIPEDA obligations arising from vendor data processing. Manages legal response to vendor security incidents that may result in regulatory action or litigation.
All Staff	Must not engage or use any vendor covered by this policy without prior notification to the IT Director. Must report any security concerns about a vendor relationship with the IT Director immediately. Must not share NorthBridge or client data with any vendor that has not been formally approved and onboarded.

10. Non-Compliance and Enforcement

Failure to comply with this policy creates direct risk to NorthBridge and its Government of Canada clients. The following consequences apply to violations of this policy.

- Engaging a Tier 1, 2, or 3 vendors without IT Director approval: Immediate escalation to the IT Director and CEO. The unauthorized vendor relationship must be suspended pending a security assessment. Disciplinary action for the responsible employee.
- Sharing NorthBridge or client data with an unapproved vendor: Treated as a potential data exposure incident under POL-004. Full incident response process initiated. Regulatory notification obligations assessed by Legal Counsel.
- Failure to complete a vendor review within the required timeframe: Formal escalation to the IT Director. Access restrictions applied to the overdue vendor until review is completed.
- Vendor failure to notify NorthBridge of an incident within contractual timeframes: Legal Counsel engaged to assess breach of contract. Vendor access suspended pending full incident assessment. Tier classification reviewed and potentially upgraded.

11. Policy Review and Approval

This policy is reviewed annually by the IT Director and approved by the Chief Executive Officer. The policy is also reviewed following any significant vendor security incident, or a material change to NorthBridge's vendor landscape.

Role	Name	Signature	Date
Author	Ashkon Irani	[Signed]	05/17/2026
Reviewer	IT Director	[Signed]	05/17/2026

Approver	Chief Executive Officer	[Signed]	05/17/2026
----------	-------------------------	----------	------------

-- End of Document --

POL-005 v1.0 | NorthBridge Technology Solutions Inc. | CONFIDENTIAL